

Security+ 3.2 · Port Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.2 — Port Security (3:50)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: 802.1X: autentica o USUÁRIO/máquina antes de dar acesso à rede via switch. RADIUS centraliza o AAA. Sem 802.1X, qualquer um conecta e tem acesso. NAC (Network Access Control) = 802.1X + postura (antivirus/patch health).

Highlights que a prova cobra

- 802.1X: autentica ANTES de dar acesso à porta do switch
- RADIUS: o backend central de AAA
- NAC: 802.1X + checagem de saúde (antivirus, patch)

Dicas de prova & Cenários Típicos

- 'requires authentication before network access'=802.1X

Cenário clássico de exame: 'switch requires login before allowing traffic'=802.1X + RADIUS.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 3.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Port Security) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Modelos de Responsabilidade Compartilhada na Nuvem:**
 - **IaaS (Infrastructure as a Service):** provedor cuida da infraestrutura física/hipervisor; cliente cuida de SO, patches, middleware, rede e dados.
 - **PaaS (Platform as a Service):** provedor cuida do hardware, SO e runtime; cliente cuida do código da aplicação e dos dados.
 - **SaaS (Software as a Service):** provedor gerencia tudo; cliente é responsável apenas pelas configurações de acesso e segurança dos próprios dados.
- **Segmentação de Rede e Segurança Perimetral:**
 - **DMZ (Demilitarized Zone):** sub-rede perimetral intermediária para servidores públicos (web, mail), isolada da rede corporativa interna por firewalls.
 - **VLANs (Virtual LANs):** isolamento lógico de tráfego na camada 2 para separar departamentos sensíveis (ex: finanças, RH, visitantes).
 - **SASE (Secure Access Service Edge):** convergência de SD-WAN e serviços de segurança em nuvem (CASB, FWaaS, ZTNA) entregues próximos ao usuário.
- **Resiliência e Tolerância a Falhas de Armazenamento:**
 - **RAID 0:** striping sem tolerância a falhas (foco exclusivo em velocidade; perda de 1 disco destrói tudo).
 - **RAID 1:** espelhamento (tolera perda de 1 disco; consome 50% do espaço total).
 - **RAID 5:** paridade distribuída (mínimo 3 discos; tolera falha de 1 disco).
 - **RAID 6:** dupla paridade (mínimo 4 discos; tolera falha simultânea de até 2 discos).
 - **RAID 10 (1+0):** combinação de espelhamento e striping (alta performance e redundância).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- RAID NÃO substitui Backup. Se um arquivo for corrompido, excluído ou criptografado por ransomware, o RAID replica o dado corrompido instantaneamente nos discos espelhados.
- Na nuvem pública, a responsabilidade sobre a classificação e sigilo dos DADOS é SEMPRE do cliente em qualquer modelo (IaaS, PaaS ou SaaS).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Serviço que centraliza a autenticação de acesso à rede (login em switch/VPN via servidor central):

- A) RADIUS
- B) DNS
- C) SMTP
- D) NTP

2. Gerencia serviços (start/stop/status) no Linux moderno:

- A) systemctl
- B) service (antigo)
- C) initd
- D) runlevel

3. Qual protocolo de autenticação utiliza tickets e é amplamente usado em ambientes Active Directory?

- A) RADIUS
- B) TACACS+
- C) Kerberos
- D) LDAP

4. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: '802.1X: autentica ANTES de dar acesso à porta do switch'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch...
- B) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C) Substituir controles técnicos preventivos por termos de adesão informais
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'RADIUS: o backend central de AAA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: RADIUS: o backend central de AAA...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'NAC: 802.1X + checagem de saúde (antivirus, patch)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: NAC: 802.1X + checagem de saúde (antivirus, patch)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: '"requires authentication before network access'=802.1X'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'requires authentication before network access'=802.1X...

8. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'switch requires login before allowing traffic'=802.1X + RADIUS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'switch requires login before allowing traffic'=802.1X + RADIUS....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: '802.1X: autentica ANTES de dar acesso à porta do switch'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'RADIUS: o backend central de AAA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RADIUS: o backend central de AAA...

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — RADIUS.

✓ **Por que está certa:** RADIUS (e TACACS+) centraliza AAA de acesso à rede. O 802.1X usa RADIUS por trás.

✗ **Por que as outras estão erradas:**

- *DNS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *SMTP*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *NTP*: É um protocolo de infraestrutura com finalidade diversa (gerenciamento de rede, integridade de DNS ou sincronismo temporal), não atuando como servidor de autenticação centralizada.

2) A — systemctl.

✓ **Por que está certa:** systemctl start/stop/status/enable — é o systemd. Ex: systemctl status ssh.

✗ **Por que as outras estão erradas:**

- *service (antigo)*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *initd*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *runlevel*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) C — Kerberos.

✓ **Por que está certa:** Kerberos usa tickets (TGT e service tickets) para autenticação mútua em redes, sendo o padrão do Active Directory.

✗ **Por que as outras estão erradas:**

- *RADIUS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *TACACS+*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *LDAP*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) A — Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 802.1X: autentica ANTES de dar acesso à porta do switch.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: RADIUS: o backend central de AAA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): RADIUS: o backend central de AAA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: NAC: 802.1X + checagem de saúde (antivirus, patch)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): NAC: 802.1X + checagem de saúde (antivirus, patch).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'requires authentication before network access'=802.1X....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 'requires authentication before network access'=802.1X.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'switch requires login before allowing traffic'=802.1X + RADIUS.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 'switch requires login before allowing traffic'=802.1X + RADIUS..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 802.1X: autentica ANTES de dar acesso à porta do switch.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: RADIUS: o backend central de AAA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): RADIUS: o backend central de AAA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

